

한전KPS(주) 상임감사 개선 · 시정 요구 · 통보

일련번호 2024-08-002
제 목 정보보안 모니터링 등 관리 방안 마련
수감부서 @@사업처
조치부서 #####
내 용

1. 업무 개요

\$\$\$\$\$\$는 「직제규정시행세칙」 제4조에 따른 별표 4에 따라 회사의 정보보안에 관한 업무 전반을 담당하는 부서¹⁾로서 보안사고 사전 예방 등을 위해 매년 정보보안 관리에 대한 지도점검을 수행하고 있으며, 정보보안 관리 사각지대 최소화 등을 위해 사업소로 하여금 체크리스트를 활용한 점검·감사를 시행하고 그 결과를 제출하도록 하고 있다.

그리고 \$\$\$\$\$\$는 2023년부터 사내 정보시스템의 지속적인 점검과 관리를 위하여 사업소로 하여금 보유 정보시스템(PC, 복합기, 네트워크, 보안장비, CCTV 등)의 현황을 분기별로 작성 및 제출하도록 하였다.

2. 관계규정 및 판단기준

\$\$\$\$\$\$는 「정보보안 업무처리기준」 제9조에 따라 정보보안감사 등을 연 1회 이상 실시하여야 하고, 정보보안 필수 조치 사항 미이행 등 정보보안 위규 사항 발생 시 「내부경영실적평가편람」 사이버보안 내재화 지수 지표에 따라 별점을 부과하는 등 위규 처리 기준을 준수하여야 한다.

1) \$\$\$\$\$\$: 회사의 정보보안에 관한 업무 전반을 담당하는 부서
%%%%%%%% : 회사의 전산 비품의 운영관리 등을 담당하는 부서

그리고 「정보보안 업무처리기준」 제6조에 따라 정보시스템 접속기록을 점검하고 정보시스템 현황을 관리하는 등 정보보안 활동을 수행하여야 한다.

따라서, \$\$\$\$\$\$는 정보보안 관련 제 규정에 따른 활동을 통해 정보보안 준수 여부를 정기적으로 점검하고, 비정상적인 운영 상태 등이 발생한 경우에는 문제점에 대해 적절히 조치하여 정보보안 문제가 발생하지 않도록 하는 것이 타당하다.

3. 감사결과 확인된 문제점

① 정보보안 관리·감독 미흡

2024. 4. 3. 조사일 현재 자체 점검·감사의 시행 현황을 점검한 결과, @@사업처는 2021. 6. 1.부터 2023. 6. 16. 사이에 총 8회에 걸쳐 정보보안 자체 점검·감사를 시행하였다.

그런데 @@사업처가 시행한 자체 점검·감사의 결과에는 일반영역 내 자료 삭제 등 모든 항목의 조치가 “완료” 된 것으로 표기되어 있고, 비인가 전산장비 무단 반입 및 사용 여부 등에 관한 정보보안 점검 결과가 “양호”로 기록되어 있으나, 이는 감사실의 조사 결과와는 상당한 차이가 있는 것으로 나타났다.

구체적으로 살펴보면, @@사업처 대리 GFD는 2021. 7. 19. 일반영역(C 드라이브) 내 매크로 소프트웨어를 설치한 후 최소 2023. 5. 20(정확한 날짜 미상)까지 해당 소프트웨어를 사용 또는 유지하여 시간외근무 허위 시행에 이용해 왔으나, 2021년부터 2023년까지 매년 시행된 자체점검 결과에는 일반영역 내 자료 삭제가 “조치 완료”로 표기되어 있다.

이를 포함하여, @@사업처 대리 OKM은 2020년 11월에서 12월 사이(정확한 날짜 미상)에 PC 1점을 소내에 임의 반입한 후 2024. 11. 1.까지

필수 보안프로그램을 미설치한 채로 시간외근무 허위 시행 등의 용도로 사용해 왔는데도, 2021년부터 2023년까지 매년 시행된 자체감사 결과에는 “비인가/개인 소유 정보통신기기 무단 반입 금지”, “필수 보안프로그램 설치” 점검 지표가 “양호”로 표기되어 있다.

그뿐만 아니라, \$\$\$\$의 지도점검 내역을 확인한 결과, 2022. 7. 11.부터 7. 12.까지 @@사업처를 대상으로 한 지도점검 결과를 포함해 2021년부터 2023년까지 총 17건의 감점 사항을 적발하였으나, 적발 내용이 ‘CMOS 패스워드 미설정’과 ‘계정정보 누출(패스워드 메모 부착 등)’에 한정되어 있고, 위규 발생에 따른 감점이 내부경영실적평가 기준과 다르게 부과된 사실이 아래 [표 1]과 같이 확인되었다.

[표 1] 정보보안 지도점검 결과 및 감점 현황

구분	소속	성명	사번	발생일자	위반내용	기준별점	부과별점
'21 년도	☞☞	HKG		'21년 10월	CMOS 미설정	3	3
	□□	ERW		'21년 10월	CMOS 미설정	3	3
'22 년도	◆◆	QAZ		'22년 6월	CMOS 미설정	3	3
	○○○	QWE		'22년 6월	CMOS 미설정	3	3
	@@	ERT		'22년 7월	CMOS 미설정	9	6
		YUI			계정정보누출		
		ASD			계정정보누출		
	◇◇	SDF		'22년 7월	계정정보누출	3	3
	■ ■	DFG		'22년 10월	CMOS 미설정	6	3
		FGH			CMOS 미설정		
'23 년도	▼▼▼▼	GHJ		'23년 6월	CMOS 미설정	3	3
	♠♠♠♠	HKJ		'23년 7월	CMOS 미설정	3	3
	○○○	JKL		'23년 8월	CMOS 미설정	3	3
	●●	ZXC		'23년 8월	CMOS 미설정	3	3
	★★★	CVB		'23년 9월	CMOS 미설정	3	3
	☆☆	BNM		'23년 8월	CMOS 미설정	3	3
	▽▽▽▽	QGH		'23년 12월	CMOS 미설정	3	3

따라서 \$\$\$\$의 정보보안 관리·감독 등의 대응 활동이 충분하지 않은 것으로 판단되고, 정보보안 지도점검 결과관리의 정확성과 공정성이 의심 받을 우려가 있다.

② 보안활동 수행 소홀

@@사업처가 \$\$\$\$의 요청에 따라 분기별(총 4회/년)로 작성하여 제출한 정보시스템 운영 현황 자료²⁾에 의하면, 자산번호, 보안스티커 번호 및 사용자 등이 확인되지 않으면서 운영체제(Operating System, OS)가 명확하지 않은 상태로 회사의 네트워크에 연결된 PC(업무망 IP 192.168.5.204, 인터넷망 PC IP 10.25.52.76)가 아래 [표 2]와 같이 존재하는 것으로 확인되었다.

[표 2] @@사업처 정보시스템 현황 자료 발췌

사업장명	구분	자산번호	보안스티커 번호	IP 주소	OS
@@ 사업처	내부망	-	-	192.168.5.204	Microsoft Windows
	외부망	-	-	10.25.52.76	

그리고, 2023. 11. 15. 네트워크 접근관리시스템(이하 “NAC”) 관리 정책 현황 자료에 의해서도 회사의 네트워크에는 연결되어 있으나, NAC가 미설치된 PC가 존재하는 것을 아래 [표 3]과 같이 확인할 수 있었다.

[표 2] @@사업처 정보시스템 현황 자료 발췌

노드 타입	에이전트 동작	IP 주소	MAC 주소	제어정책	호스트명
PC	설치안됨	192.168.5.204	B8:AE:ED:AD:19:1E	차단정책 - NAC 미설치	KPSKPS

2) 「정보시스템 운영 현황 제출 협조 요청」, #####-1873(2023. 2. 24.)

「정보시스템 운영 현황 제출 협조 요청(’23년 2분기)」, #####-4776(2023. 6. 14.)

「정보시스템 운영 현황 제출 협조 요청(’23년 3분기)」, #####-7794(2023. 9. 22.)

「정보시스템 운영 현황 제출 협조 요청(’23년 4분기)」, #####-10031(2023. 12. 21..)

그럼에도 \$\$\$\$는 관련 실태 파악 및 점검 등의 필요한 조치를 취하지 아니한 채 그대로 두었고, 그 결과 @@사업처 일부 직원의 부당한 행위가 미연에 방지되거나 중도에 차단되지 못하는 결과로 이어지게 되었으며, 정보보안 우려 상황³⁾에 대한 점검 또한 긴요한 실정이다.

관계부서 등 의견

#####(\$\$\$\$)는 조사 결과에 별다른 이견을 제기하지 않으면서 사업소가 시행하는 자체 점검·감사와 \$\$\$\$가 시행하는 지도점검 등의 정보보안 활동 강화를 통해 동일 사례가 재발하지 않도록 하는 한편, 지도점검 결과 관리의 정확성과 공정성이 훼손되지 않도록 관련 업무에 더욱 주의를 기울이겠다는 의견을 제시하였다.

그리고, 사업소에서 제출한 정보시스템 운영 현황 제출자료와 관련하여 사후적 관리 조치가 부족하였던 사실을 인정하면서, 전산 비품 운영관리 등을 담당하는 부서인 %%%%%%%%%와의 긴밀한 협력 및 회사의 정보보안 자산을 적극 이용하는 등의 방법으로 정보보안 우려 상황에 대한 특별 점검을 시행하고 이에 따른 보강 대책을 마련하겠다는 의견을 제시하였다.

조치할 사항

#####장은

- ① 정보보안 우려 상황 해소를 위해 특별 점검 조직(TF) 구성 및 가용 가능 정보보안 자산 동원 등의 방법으로 비정상적인 상태로 회사의

3) NAC 미설치 상태로 네트워크에 연결되어 있는 것으로 파악되는 PC는 2024. 1. 11. 기준 총 81대, 같은 해 2. 13. 기준 총 79대로 회사의 관리·통제 외의 범위에서 부적절한 용도에 활용될 우려가 있는 실정

네트워크에 연결된 PC의 존재 여부 등을 파악 및 점검한 후 그 결과를 보고하시고, **【시정】**

- ② 정보보안 자산을 통해 회사의 정보보안 상황을 상시 모니터링하고 관리할 수 있는 방안을 마련하시기 바라며, **【개선】**
- ③ 앞으로 정보보안 관리·감독이 미흡하거나 제반 보안활동 수행을 소홀히 하는 일이 없도록 관련 업무를 철저히 하시기 바랍니다. **【통보】**